

TP2 – Analyse de Vulnérabilités avec Nessus

Nom et Prénom :Laanaya Sara

Voici les adrss ip

```
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:98:86:c2 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.106/24 brd 192.168.56.255 scope global eth0
    inet6 fe80::a00:27ff:fe98:86c2/64 scope link
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$
```

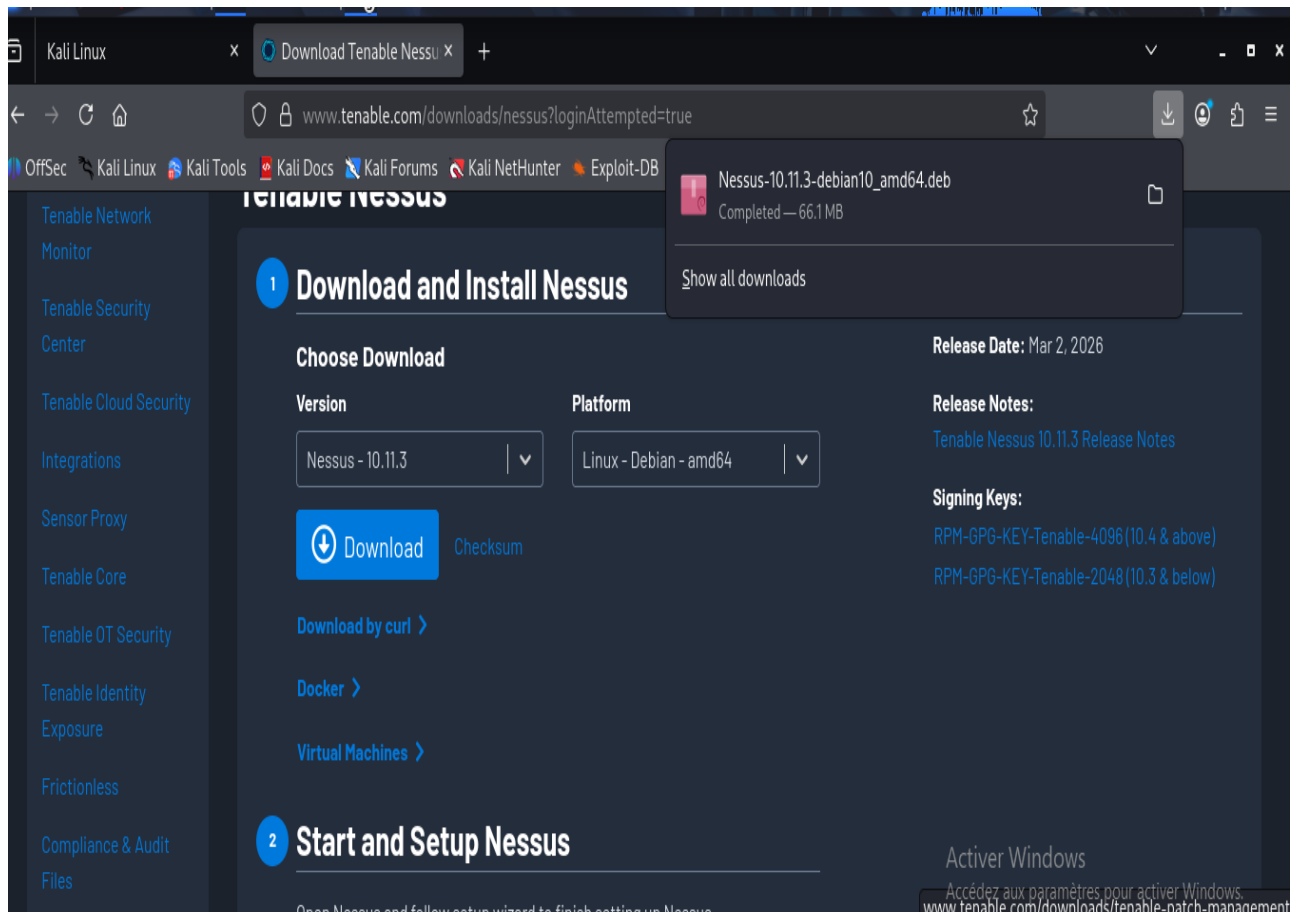
```
(kali@kali)-[~/Downloads]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:1f:b7:23 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 80283sec preferred_lft 80283sec
    inet6 fd00::90d4:b442:e5:1727/64 scope global dynamic noprefixroute
        valid_lft 86217sec preferred_lft 14217sec
    inet6 fe80::627f:6a43:e5e5:18/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:c2:80:49 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.105/24 brd 192.168.56.255 scope global dynamic noprefixroute eth1
        valid_lft 488sec preferred_lft 488sec
    inet6 fe80::af7b:3e18:f3b3:8748/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

```
(kali@kali)-[~/Downloads]
$ ping 192.168.56.106
PING 192.168.56.106 (192.168.56.106) 56(84) bytes of data.
64 bytes from 192.168.56.106: icmp_seq=1 ttl=64 time=5.17 ms
64 bytes from 192.168.56.106: icmp_seq=2 ttl=64 time=3.29 ms
64 bytes from 192.168.56.106: icmp_seq=3 ttl=64 time=3.62 ms
^C
— 192.168.56.106 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2004ms
rtt min/avg/max/mdev = 3.289/4.026/5.168/0.818 ms

(kali@kali)-[~/Downloads]
$
```

Le ping est réussi

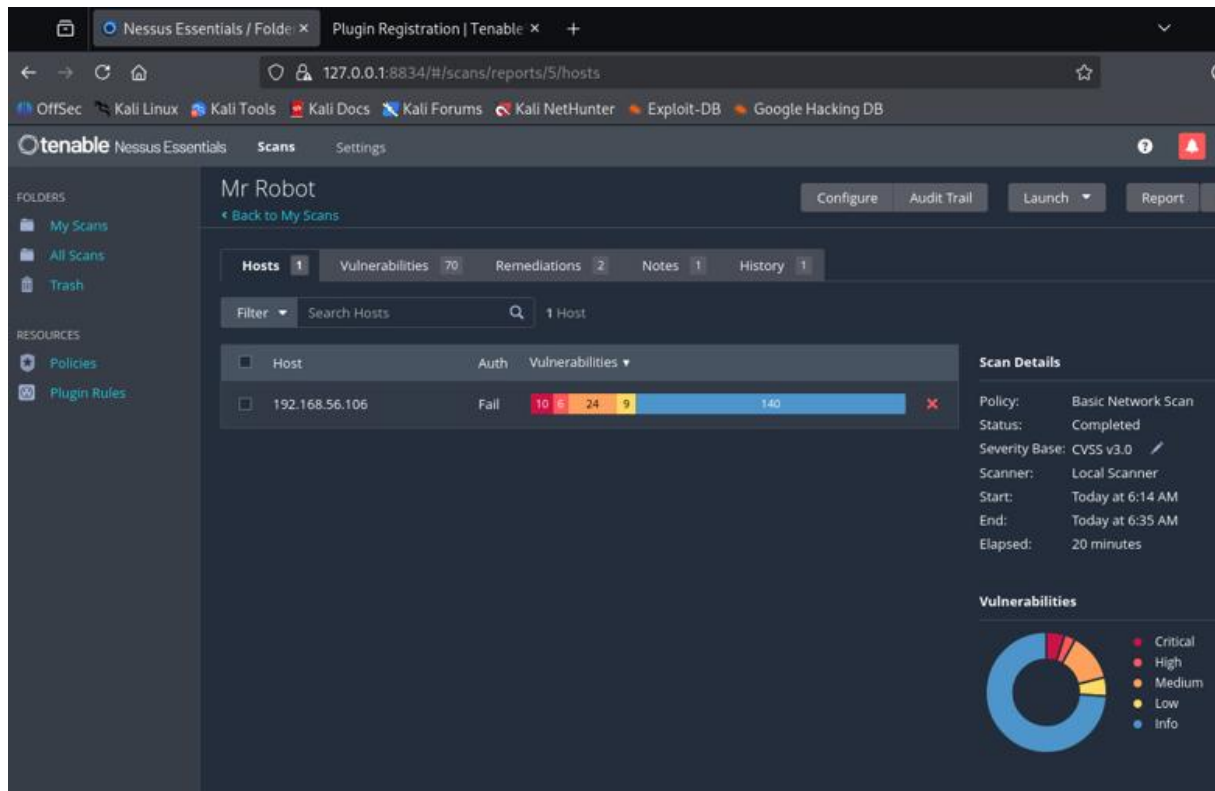
Incluez une capture d'écran montrant la fin de l'installation de Nessus



```
(kali@kali)-[~/Downloads]
$ sudo systemctl start nessusd.service

(kali@kali)-[~/Downloads]
$ sudo systemctl status
nessusd.service
● kali
   State: running
  Units: 290 loaded (incl. loaded aliases)
    Jobs: 1 queued
  Failed: 0 units
   Since: Sat 2026-03-07 05:08:55 EST; 14min ago
systemd: 259-1
Tainted: unmerged-bin
  CGroup: /
          └─init.scope
```

Il affiche running

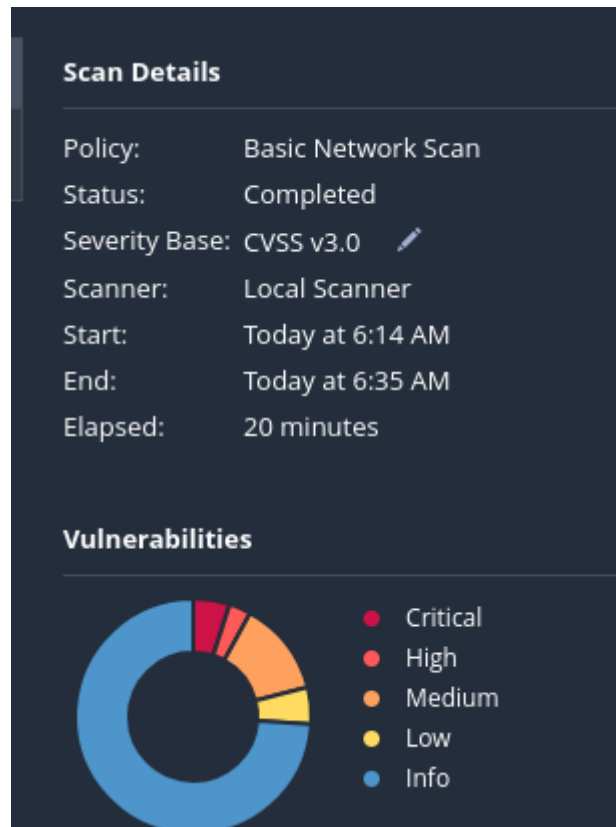


On remarque dans la capture d'écran l'adresse IP : 192.168.56.106 c'est l'adresse de Metasploitable 2 ou bien la cible (avec le nom Mr Robot)

Capture d'écran du tableau de bord des résultats montrant la répartition des vulnérabilités

☐	Host	Auth	Vulnerabilities ▼	
☐	192.168.56.106	Fail	10 6 24 9	140

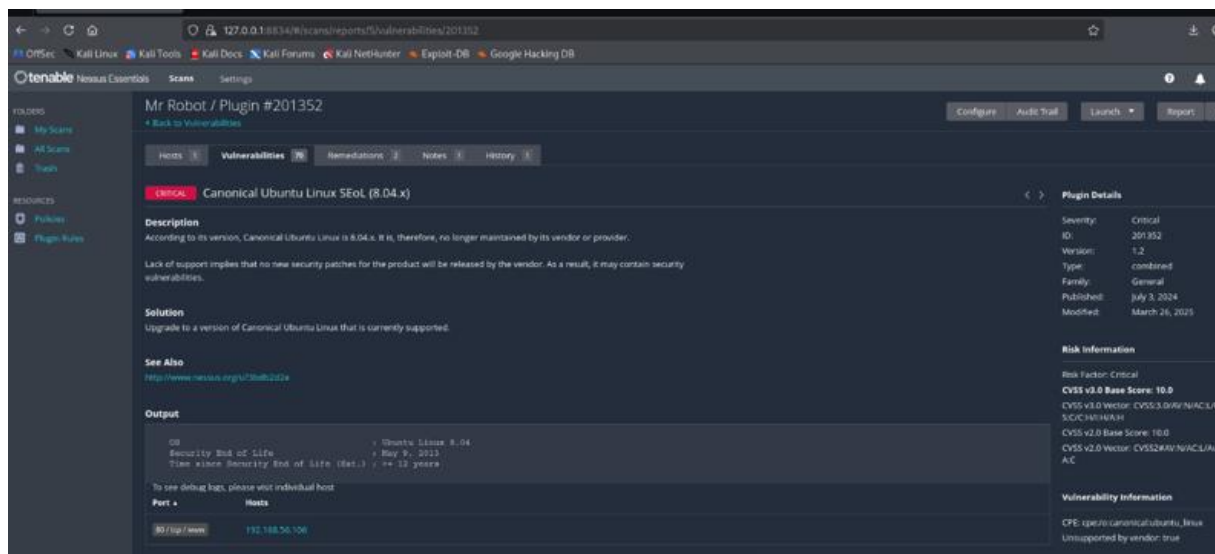
Identification de la cible : L'adresse IP ciblée est bien **192.168.56.106** (la machine Metasploitable2).



On constate que le scan a duré **20 minutes** et qu'il utilise la norme standardisée **CVSS v3.0** pour évaluer et noter la sévérité des failles.

Le graphique répartit visuellement toutes les alertes remontées par Nessus en fonction de leur niveau de criticité (rouge pour Critique, orange pour Élevé ...). La large zone bleue (Info) montre que Nessus a récolté beaucoup de données informatives qui ne sont pas forcément des failles dangereuses.

On commence par Critical :



Nom de la faille : Canonical Ubuntu Linux SEoL (8.04.x)

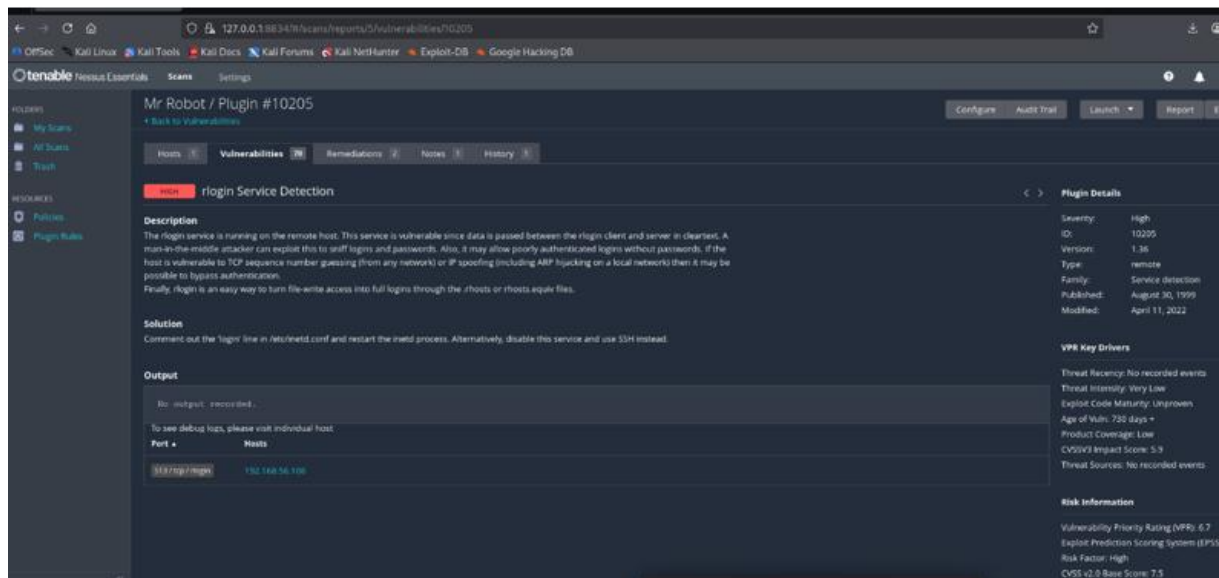
Identifiant du plugin (Plugin ID) : 201352

Description résumée : Le système d'exploitation Ubuntu 8.04 installé sur la cible a atteint sa fin de vie (End of Life) et ne reçoit plus aucun correctif de sécurité de la part de l'éditeur, le laissant exposé à toutes les nouvelles failles.

Solution de remédiation : Mettre à niveau (Upgrade) vers une version d'Ubuntu Linux qui est actuellement supportée par l'éditeur.

Score CVSS v3.0 : 10.0 (Le score maximum, ce qui confirme son niveau critique).

Maintenant on passe vers high :



Nom de la faille : rlogin Service Detection

Identifiant du plugin (Plugin ID) : 10205

Description résumée : Le service *rlogin* est actif sur la machine et transmet les données (y compris les identifiants et mots de passe) en clair (sans chiffrement), ce qui permet à un attaquant sur le réseau de les intercepter via une attaque de type "Man-in-the-Middle".

Solution de remédiation : Désactiver ce service en commentant la ligne 'login' dans le fichier `/etc/inetd.conf` et redémarrer le processus, ou utiliser un protocole sécurisé comme SSH à la place.

Score CVSS : indique un **Base Score CVSS v2.0 de 7.5**.

Conclusion

un scanner de vulnérabilités comme Nessus est un outil indispensable car il permet d'automatiser la détection des failles, d'évaluer leur criticité (grâce aux scores CVSS) et de fournir des solutions de remédiation concrètes pour sécuriser le système.

La différence entre Nmap e Nessus réside dans leur objectif : **Nmap** est un outil de reconnaissance qui cartographie le réseau et identifie les ports ouverts et les services actifs (les "portes d'entrée"). **Nessus**, quant à lui, va plus loin : il se connecte à ces services et interroge sa base de données (les plugins) pour vérifier si les versions installées contiennent des faiblesses de sécurité publiquement connues (CVE) et exploitables.